

Secure Software Development Lifecycle Policy

Sample IT Company - IT Policy Detail Document

Draft template v1.0 | Prepared: 05 Aug 2026

Defines secure design, coding, code review, testing, secrets protection, dependency scanning, release gates, and developer responsibilities.

Document notice: This is a sample policy template for planning, training, and documentation purposes. It is not legal advice and should be reviewed by the organization's legal, compliance, HR, security, and technology leadership before adoption.

Document owner	Chief Information Security Officer / IT Governance
Applies to	Employees, contractors, vendors, systems, applications, and company-managed information
Review cycle	At least annually or after major business, legal, security, or technology changes
Approval body	Risk committee, IT leadership, Legal/Compliance, and HR as applicable

1. Purpose and Scope

This section explains how the secure software development lifecycle policy is applied for purpose and scope. The company expects every business unit to translate these requirements into practical working procedures, system settings, and evidence records. Teams must consider purpose, scope, applicability, business context when designing controls, approving exceptions, and performing periodic reviews. Where a business process cannot meet the requirement exactly, the owner must document the risk, define compensating controls, agree an expiry date, and obtain approval before continuing. This policy is intended to be used as a detailed baseline and must be tailored to local laws, contract obligations, customer commitments, and the organization-specific operating model.

The control objective for this page is to make purpose measurable, repeatable, and auditable. Policy owners should convert the statements below into standard operating procedures, workflow controls, employee guidance, and system configuration baselines. Each requirement should be traceable to a business risk, a responsible role, and a retained evidence artifact.

Mandatory requirements

- A formal owner must be accountable for purpose and scope decisions, approvals, escalations, and evidence retention.
- Any activity covered by this policy must follow least privilege, need-to-know access, approved tools, and documented business justification.
- Sensitive information must be classified, labeled, stored, transmitted, retained, and disposed of only through approved company processes.
- Exceptions must be time-bound, risk-assessed, approved by the correct authority, and reviewed before expiry.
- Control failures, suspected incidents, policy violations, or unusual behavior must be reported promptly through the approved security or IT support channel.
- Managers must ensure their teams understand applicable procedures and complete required training before handling regulated, confidential, or customer data.

Implementation guidance

Implementation should start by confirming system scope, business owner, data classification, user groups, and supporting procedures. The IT team should define configuration standards, monitoring requirements, escalation thresholds, and audit evidence before production rollout. Business teams should document where the policy affects daily work, customer obligations, data sharing, procurement, engineering, support operations, and exception handling.

Review questions

- Confirm the policy owner and backup owner are assigned.
- Verify scope includes employees, contractors, systems, and third parties where applicable.
- Classify related data and confirm approved storage locations.
- Document approval, exception, and escalation paths.
- Define evidence records needed for audit and compliance review.

Records to retain: approval records, risk decisions, access requests, exception approvals, incident tickets, training evidence, configuration baselines, audit results, and management review notes where relevant.

2. Policy Principles

This section explains how the secure software development lifecycle policy is applied for policy principles. The company expects every business unit to translate these requirements into practical working procedures, system settings, and evidence records. Teams must consider principles, baseline controls, risk alignment, behavior expectations when designing controls, approving exceptions, and performing periodic reviews. Where a business process cannot meet the requirement exactly, the owner must document the risk, define compensating controls, agree an expiry date, and obtain approval before continuing. This policy is intended to be used as a detailed baseline and must be tailored to local laws, contract obligations, customer commitments, and the organization-specific operating model.

The control objective for this page is to make principles measurable, repeatable, and auditable. Policy owners should convert the statements below into standard operating procedures, workflow controls, employee guidance, and system configuration baselines. Each requirement should be traceable to a business risk, a responsible role, and a retained evidence artifact.

Mandatory requirements

- A formal owner must be accountable for policy principles decisions, approvals, escalations, and evidence retention.
- Any activity covered by this policy must follow least privilege, need-to-know access, approved tools, and documented business justification.
- Sensitive information must be classified, labeled, stored, transmitted, retained, and disposed of only through approved company processes.
- Exceptions must be time-bound, risk-assessed, approved by the correct authority, and reviewed before expiry.
- Control failures, suspected incidents, policy violations, or unusual behavior must be reported promptly through the approved security or IT support channel.
- Managers must ensure their teams understand applicable procedures and complete required training before handling regulated, confidential, or customer data.

Control area	Minimum expectation	Evidence example
Ownership	A named owner maintains this policy and related standards.	Policy approval record and review log
Risk review	Policy controls are reviewed against business risk and threat changes.	Risk register entry or review minutes
Access control	Access is approved, limited, and removed when no longer needed.	Access request, approval, and review evidence
Monitoring	Relevant system activity is logged and reviewed using approved tools.	Alert queue, audit log, or SIEM report
Training	Affected users complete applicable training before using the process.	Training completion report

Records to retain: approval records, risk decisions, access requests, exception approvals, incident tickets, training evidence, configuration baselines, audit results, and management review notes where relevant.

3. Roles and Responsibilities

This section explains how the secure software development lifecycle policy is applied for roles and responsibilities. The company expects every business unit to translate these requirements into practical working procedures, system settings, and evidence records. Teams must consider accountability, owners, employees, managers, IT security when designing controls, approving exceptions, and performing periodic reviews. Where a business process cannot meet the requirement exactly, the owner must document the risk, define compensating controls, agree an expiry date, and obtain approval before continuing. This policy is intended to be used as a detailed baseline and must be tailored to local laws, contract obligations, customer commitments, and the organization-specific operating model.

The control objective for this page is to make accountability measurable, repeatable, and auditable. Policy owners should convert the statements below into standard operating procedures, workflow controls, employee guidance, and system configuration baselines. Each requirement should be traceable to a business risk, a responsible role, and a retained evidence artifact.

Mandatory requirements

- A formal owner must be accountable for roles and responsibilities decisions, approvals, escalations, and evidence retention.
- Any activity covered by this policy must follow least privilege, need-to-know access, approved tools, and documented business justification.
- Sensitive information must be classified, labeled, stored, transmitted, retained, and disposed of only through approved company processes.
- Exceptions must be time-bound, risk-assessed, approved by the correct authority, and reviewed before expiry.
- Control failures, suspected incidents, policy violations, or unusual behavior must be reported promptly through the approved security or IT support channel.
- Managers must ensure their teams understand applicable procedures and complete required training before handling regulated, confidential, or customer data.

Implementation guidance

Implementation should start by confirming system scope, business owner, data classification, user groups, and supporting procedures. The IT team should define configuration standards, monitoring requirements, escalation thresholds, and audit evidence before production rollout. Business teams should document where the policy affects daily work, customer obligations, data sharing, procurement, engineering, support operations, and exception handling.

Review questions

- Confirm the policy owner and backup owner are assigned.
- Verify scope includes employees, contractors, systems, and third parties where applicable.
- Classify related data and confirm approved storage locations.
- Document approval, exception, and escalation paths.
- Define evidence records needed for audit and compliance review.

Records to retain: approval records, risk decisions, access requests, exception approvals, incident tickets, training evidence, configuration baselines, audit results, and management review notes where relevant.

4. Governance and Approval

This section explains how the secure software development lifecycle policy is applied for governance and approval. The company expects every business unit to translate these requirements into practical working procedures, system settings, and evidence records. Teams must consider approval workflow, oversight, exceptions, review cadence when designing controls, approving exceptions, and performing periodic reviews. Where a business process cannot meet the requirement exactly, the owner must document the risk, define compensating controls, agree an expiry date, and obtain approval before continuing. This policy is intended to be used as a detailed baseline and must be tailored to local laws, contract obligations, customer commitments, and the organization-specific operating model.

The control objective for this page is to make approval workflow measurable, repeatable, and auditable. Policy owners should convert the statements below into standard operating procedures, workflow controls, employee guidance, and system configuration baselines. Each requirement should be traceable to a business risk, a responsible role, and a retained evidence artifact.

Mandatory requirements

- A formal owner must be accountable for governance and approval decisions, approvals, escalations, and evidence retention.
- Any activity covered by this policy must follow least privilege, need-to-know access, approved tools, and documented business justification.
- Sensitive information must be classified, labeled, stored, transmitted, retained, and disposed of only through approved company processes.
- Exceptions must be time-bound, risk-assessed, approved by the correct authority, and reviewed before expiry.
- Control failures, suspected incidents, policy violations, or unusual behavior must be reported promptly through the approved security or IT support channel.
- Managers must ensure their teams understand applicable procedures and complete required training before handling regulated, confidential, or customer data.

Implementation guidance

Implementation should start by confirming system scope, business owner, data classification, user groups, and supporting procedures. The IT team should define configuration standards, monitoring requirements, escalation thresholds, and audit evidence before production rollout. Business teams should document where the policy affects daily work, customer obligations, data sharing, procurement, engineering, support operations, and exception handling.

Review questions

- Confirm the policy owner and backup owner are assigned.
- Verify scope includes employees, contractors, systems, and third parties where applicable.
- Classify related data and confirm approved storage locations.
- Document approval, exception, and escalation paths.
- Define evidence records needed for audit and compliance review.

Records to retain: approval records, risk decisions, access requests, exception approvals, incident tickets, training evidence, configuration baselines, audit results, and management review notes where relevant.

5. Core Requirements

This section explains how the secure software development lifecycle policy is applied for core requirements. The company expects every business unit to translate these requirements into practical working procedures, system settings, and evidence records. Teams must consider mandatory rules, minimum controls, allowed activities, restricted activities when designing controls, approving exceptions, and performing periodic reviews. Where a business process cannot meet the requirement exactly, the owner must document the risk, define compensating controls, agree an expiry date, and obtain approval before continuing. This policy is intended to be used as a detailed baseline and must be tailored to local laws, contract obligations, customer commitments, and the organization-specific operating model.

The control objective for this page is to make mandatory rules measurable, repeatable, and auditable. Policy owners should convert the statements below into standard operating procedures, workflow controls, employee guidance, and system configuration baselines. Each requirement should be traceable to a business risk, a responsible role, and a retained evidence artifact.

Mandatory requirements

- A formal owner must be accountable for core requirements decisions, approvals, escalations, and evidence retention.
- Any activity covered by this policy must follow least privilege, need-to-know access, approved tools, and documented business justification.
- Sensitive information must be classified, labeled, stored, transmitted, retained, and disposed of only through approved company processes.
- Exceptions must be time-bound, risk-assessed, approved by the correct authority, and reviewed before expiry.
- Control failures, suspected incidents, policy violations, or unusual behavior must be reported promptly through the approved security or IT support channel.
- Managers must ensure their teams understand applicable procedures and complete required training before handling regulated, confidential, or customer data.

Implementation guidance

Implementation should start by confirming system scope, business owner, data classification, user groups, and supporting procedures. The IT team should define configuration standards, monitoring requirements, escalation thresholds, and audit evidence before production rollout. Business teams should document where the policy affects daily work, customer obligations, data sharing, procurement, engineering, support operations, and exception handling.

Review questions

- Confirm the policy owner and backup owner are assigned.
- Verify scope includes employees, contractors, systems, and third parties where applicable.
- Classify related data and confirm approved storage locations.
- Document approval, exception, and escalation paths.
- Define evidence records needed for audit and compliance review.

Records to retain: approval records, risk decisions, access requests, exception approvals, incident tickets, training evidence, configuration baselines, audit results, and management review notes where relevant.

6. Operational Procedures

This section explains how the secure software development lifecycle policy is applied for operational procedures. The company expects every business unit to translate these requirements into practical working procedures, system settings, and evidence records. Teams must consider day-to-day process, request flow, documentation, evidence when designing controls, approving exceptions, and performing periodic reviews. Where a business process cannot meet the requirement exactly, the owner must document the risk, define compensating controls, agree an expiry date, and obtain approval before continuing. This policy is intended to be used as a detailed baseline and must be tailored to local laws, contract obligations, customer commitments, and the organization-specific operating model.

The control objective for this page is to make day-to-day process measurable, repeatable, and auditable. Policy owners should convert the statements below into standard operating procedures, workflow controls, employee guidance, and system configuration baselines. Each requirement should be traceable to a business risk, a responsible role, and a retained evidence artifact.

Mandatory requirements

- A formal owner must be accountable for operational procedures decisions, approvals, escalations, and evidence retention.
- Any activity covered by this policy must follow least privilege, need-to-know access, approved tools, and documented business justification.
- Sensitive information must be classified, labeled, stored, transmitted, retained, and disposed of only through approved company processes.
- Exceptions must be time-bound, risk-assessed, approved by the correct authority, and reviewed before expiry.
- Control failures, suspected incidents, policy violations, or unusual behavior must be reported promptly through the approved security or IT support channel.
- Managers must ensure their teams understand applicable procedures and complete required training before handling regulated, confidential, or customer data.

Implementation guidance

Implementation should start by confirming system scope, business owner, data classification, user groups, and supporting procedures. The IT team should define configuration standards, monitoring requirements, escalation thresholds, and audit evidence before production rollout. Business teams should document where the policy affects daily work, customer obligations, data sharing, procurement, engineering, support operations, and exception handling.

Review questions

- Confirm the policy owner and backup owner are assigned.
- Verify scope includes employees, contractors, systems, and third parties where applicable.
- Classify related data and confirm approved storage locations.
- Document approval, exception, and escalation paths.
- Define evidence records needed for audit and compliance review.

Records to retain: approval records, risk decisions, access requests, exception approvals, incident tickets, training evidence, configuration baselines, audit results, and management review notes where relevant.

7. Access and Authorization

This section explains how the secure software development lifecycle policy is applied for access and authorization. The company expects every business unit to translate these requirements into practical working procedures, system settings, and evidence records. Teams must consider least privilege, need to know, role approval, periodic reviews when designing controls, approving exceptions, and performing periodic reviews. Where a business process cannot meet the requirement exactly, the owner must document the risk, define compensating controls, agree an expiry date, and obtain approval before continuing. This policy is intended to be used as a detailed baseline and must be tailored to local laws, contract obligations, customer commitments, and the organization-specific operating model.

The control objective for this page is to make least privilege measurable, repeatable, and auditable. Policy owners should convert the statements below into standard operating procedures, workflow controls, employee guidance, and system configuration baselines. Each requirement should be traceable to a business risk, a responsible role, and a retained evidence artifact.

Mandatory requirements

- A formal owner must be accountable for access and authorization decisions, approvals, escalations, and evidence retention.
- Any activity covered by this policy must follow least privilege, need-to-know access, approved tools, and documented business justification.
- Sensitive information must be classified, labeled, stored, transmitted, retained, and disposed of only through approved company processes.
- Exceptions must be time-bound, risk-assessed, approved by the correct authority, and reviewed before expiry.
- Control failures, suspected incidents, policy violations, or unusual behavior must be reported promptly through the approved security or IT support channel.
- Managers must ensure their teams understand applicable procedures and complete required training before handling regulated, confidential, or customer data.

Control area	Minimum expectation	Evidence example
Ownership	A named owner maintains this policy and related standards.	Policy approval record and review log
Risk review	Policy controls are reviewed against business risk and threat changes.	Risk register entry or review minutes
Access control	Access is approved, limited, and removed when no longer needed.	Access request, approval, and review evidence
Monitoring	Relevant system activity is logged and reviewed using approved tools.	Alert queue, audit log, or SIEM report
Training	Affected users complete applicable training before using the process.	Training completion report

Records to retain: approval records, risk decisions, access requests, exception approvals, incident tickets, training evidence, configuration baselines, audit results, and management review notes where relevant.

8. Data Protection Requirements

This section explains how the secure software development lifecycle policy is applied for data protection requirements. The company expects every business unit to translate these requirements into practical working procedures, system settings, and evidence records. Teams must consider classification, storage, sharing, encryption, retention when designing controls, approving exceptions, and performing periodic reviews. Where a business process cannot meet the requirement exactly, the owner must document the risk, define compensating controls, agree an expiry date, and obtain approval before continuing. This policy is intended to be used as a detailed baseline and must be tailored to local laws, contract obligations, customer commitments, and the organization-specific operating model.

The control objective for this page is to make classification measurable, repeatable, and auditable. Policy owners should convert the statements below into standard operating procedures, workflow controls, employee guidance, and system configuration baselines. Each requirement should be traceable to a business risk, a responsible role, and a retained evidence artifact.

Mandatory requirements

- A formal owner must be accountable for data protection requirements decisions, approvals, escalations, and evidence retention.
- Any activity covered by this policy must follow least privilege, need-to-know access, approved tools, and documented business justification.
- Sensitive information must be classified, labeled, stored, transmitted, retained, and disposed of only through approved company processes.
- Exceptions must be time-bound, risk-assessed, approved by the correct authority, and reviewed before expiry.
- Control failures, suspected incidents, policy violations, or unusual behavior must be reported promptly through the approved security or IT support channel.
- Managers must ensure their teams understand applicable procedures and complete required training before handling regulated, confidential, or customer data.

Implementation guidance

Implementation should start by confirming system scope, business owner, data classification, user groups, and supporting procedures. The IT team should define configuration standards, monitoring requirements, escalation thresholds, and audit evidence before production rollout. Business teams should document where the policy affects daily work, customer obligations, data sharing, procurement, engineering, support operations, and exception handling.

Review questions

- Confirm the policy owner and backup owner are assigned.
- Verify scope includes employees, contractors, systems, and third parties where applicable.
- Classify related data and confirm approved storage locations.
- Document approval, exception, and escalation paths.
- Define evidence records needed for audit and compliance review.

Records to retain: approval records, risk decisions, access requests, exception approvals, incident tickets, training evidence, configuration baselines, audit results, and management review notes where relevant.

9. Technology Controls

This section explains how the secure software development lifecycle policy is applied for technology controls. The company expects every business unit to translate these requirements into practical working procedures, system settings, and evidence records. Teams must consider configuration, monitoring, logging, automation, technical safeguards when designing controls, approving exceptions, and performing periodic reviews. Where a business process cannot meet the requirement exactly, the owner must document the risk, define compensating controls, agree an expiry date, and obtain approval before continuing. This policy is intended to be used as a detailed baseline and must be tailored to local laws, contract obligations, customer commitments, and the organization-specific operating model.

The control objective for this page is to make configuration measurable, repeatable, and auditable. Policy owners should convert the statements below into standard operating procedures, workflow controls, employee guidance, and system configuration baselines. Each requirement should be traceable to a business risk, a responsible role, and a retained evidence artifact.

Mandatory requirements

- A formal owner must be accountable for technology controls decisions, approvals, escalations, and evidence retention.
- Any activity covered by this policy must follow least privilege, need-to-know access, approved tools, and documented business justification.
- Sensitive information must be classified, labeled, stored, transmitted, retained, and disposed of only through approved company processes.
- Exceptions must be time-bound, risk-assessed, approved by the correct authority, and reviewed before expiry.
- Control failures, suspected incidents, policy violations, or unusual behavior must be reported promptly through the approved security or IT support channel.
- Managers must ensure their teams understand applicable procedures and complete required training before handling regulated, confidential, or customer data.

Implementation guidance

Implementation should start by confirming system scope, business owner, data classification, user groups, and supporting procedures. The IT team should define configuration standards, monitoring requirements, escalation thresholds, and audit evidence before production rollout. Business teams should document where the policy affects daily work, customer obligations, data sharing, procurement, engineering, support operations, and exception handling.

Review questions

- Confirm the policy owner and backup owner are assigned.
- Verify scope includes employees, contractors, systems, and third parties where applicable.
- Classify related data and confirm approved storage locations.
- Document approval, exception, and escalation paths.
- Define evidence records needed for audit and compliance review.

Records to retain: approval records, risk decisions, access requests, exception approvals, incident tickets, training evidence, configuration baselines, audit results, and management review notes where relevant.

10. User Behavior Requirements

This section explains how the secure software development lifecycle policy is applied for user behavior requirements. The company expects every business unit to translate these requirements into practical working procedures, system settings, and evidence records. Teams must consider expected conduct, safe handling, reporting, prohibited behaviors when designing controls, approving exceptions, and performing periodic reviews. Where a business process cannot meet the requirement exactly, the owner must document the risk, define compensating controls, agree an expiry date, and obtain approval before continuing. This policy is intended to be used as a detailed baseline and must be tailored to local laws, contract obligations, customer commitments, and the organization-specific operating model.

The control objective for this page is to make expected conduct measurable, repeatable, and auditable. Policy owners should convert the statements below into standard operating procedures, workflow controls, employee guidance, and system configuration baselines. Each requirement should be traceable to a business risk, a responsible role, and a retained evidence artifact.

Mandatory requirements

- A formal owner must be accountable for user behavior requirements decisions, approvals, escalations, and evidence retention.
- Any activity covered by this policy must follow least privilege, need-to-know access, approved tools, and documented business justification.
- Sensitive information must be classified, labeled, stored, transmitted, retained, and disposed of only through approved company processes.
- Exceptions must be time-bound, risk-assessed, approved by the correct authority, and reviewed before expiry.
- Control failures, suspected incidents, policy violations, or unusual behavior must be reported promptly through the approved security or IT support channel.
- Managers must ensure their teams understand applicable procedures and complete required training before handling regulated, confidential, or customer data.

Implementation guidance

Implementation should start by confirming system scope, business owner, data classification, user groups, and supporting procedures. The IT team should define configuration standards, monitoring requirements, escalation thresholds, and audit evidence before production rollout. Business teams should document where the policy affects daily work, customer obligations, data sharing, procurement, engineering, support operations, and exception handling.

Review questions

- Confirm the policy owner and backup owner are assigned.
- Verify scope includes employees, contractors, systems, and third parties where applicable.
- Classify related data and confirm approved storage locations.
- Document approval, exception, and escalation paths.
- Define evidence records needed for audit and compliance review.

Records to retain: approval records, risk decisions, access requests, exception approvals, incident tickets, training evidence, configuration baselines, audit results, and management review notes where relevant.

11. Monitoring and Logging

This section explains how the secure software development lifecycle policy is applied for monitoring and logging. The company expects every business unit to translate these requirements into practical working procedures, system settings, and evidence records. Teams must consider audit trails, privacy-aware monitoring, alert review, log retention when designing controls, approving exceptions, and performing periodic reviews. Where a business process cannot meet the requirement exactly, the owner must document the risk, define compensating controls, agree an expiry date, and obtain approval before continuing. This policy is intended to be used as a detailed baseline and must be tailored to local laws, contract obligations, customer commitments, and the organization-specific operating model.

The control objective for this page is to make audit trails measurable, repeatable, and auditable. Policy owners should convert the statements below into standard operating procedures, workflow controls, employee guidance, and system configuration baselines. Each requirement should be traceable to a business risk, a responsible role, and a retained evidence artifact.

Mandatory requirements

- A formal owner must be accountable for monitoring and logging decisions, approvals, escalations, and evidence retention.
- Any activity covered by this policy must follow least privilege, need-to-know access, approved tools, and documented business justification.
- Sensitive information must be classified, labeled, stored, transmitted, retained, and disposed of only through approved company processes.
- Exceptions must be time-bound, risk-assessed, approved by the correct authority, and reviewed before expiry.
- Control failures, suspected incidents, policy violations, or unusual behavior must be reported promptly through the approved security or IT support channel.
- Managers must ensure their teams understand applicable procedures and complete required training before handling regulated, confidential, or customer data.

Implementation guidance

Implementation should start by confirming system scope, business owner, data classification, user groups, and supporting procedures. The IT team should define configuration standards, monitoring requirements, escalation thresholds, and audit evidence before production rollout. Business teams should document where the policy affects daily work, customer obligations, data sharing, procurement, engineering, support operations, and exception handling.

Review questions

- Confirm the policy owner and backup owner are assigned.
- Verify scope includes employees, contractors, systems, and third parties where applicable.
- Classify related data and confirm approved storage locations.
- Document approval, exception, and escalation paths.
- Define evidence records needed for audit and compliance review.

Records to retain: approval records, risk decisions, access requests, exception approvals, incident tickets, training evidence, configuration baselines, audit results, and management review notes where relevant.

12. Incident and Escalation Handling

This section explains how the secure software development lifecycle policy is applied for incident and escalation handling. The company expects every business unit to translate these requirements into practical working procedures, system settings, and evidence records. Teams must consider reporting, triage, containment, communications, evidence when designing controls, approving exceptions, and performing periodic reviews. Where a business process cannot meet the requirement exactly, the owner must document the risk, define compensating controls, agree an expiry date, and obtain approval before continuing. This policy is intended to be used as a detailed baseline and must be tailored to local laws, contract obligations, customer commitments, and the organization-specific operating model.

The control objective for this page is to make reporting measurable, repeatable, and auditable. Policy owners should convert the statements below into standard operating procedures, workflow controls, employee guidance, and system configuration baselines. Each requirement should be traceable to a business risk, a responsible role, and a retained evidence artifact.

Mandatory requirements

- A formal owner must be accountable for incident and escalation handling decisions, approvals, escalations, and evidence retention.
- Any activity covered by this policy must follow least privilege, need-to-know access, approved tools, and documented business justification.
- Sensitive information must be classified, labeled, stored, transmitted, retained, and disposed of only through approved company processes.
- Exceptions must be time-bound, risk-assessed, approved by the correct authority, and reviewed before expiry.
- Control failures, suspected incidents, policy violations, or unusual behavior must be reported promptly through the approved security or IT support channel.
- Managers must ensure their teams understand applicable procedures and complete required training before handling regulated, confidential, or customer data.

Control area	Minimum expectation	Evidence example
Ownership	A named owner maintains this policy and related standards.	Policy approval record and review log
Risk review	Policy controls are reviewed against business risk and threat changes.	Risk register entry or review minutes
Access control	Access is approved, limited, and removed when no longer needed.	Access request, approval, and review evidence
Monitoring	Relevant system activity is logged and reviewed using approved tools.	Alert queue, audit log, or SIEM report
Training	Affected users complete applicable training before using the process.	Training completion report

Records to retain: approval records, risk decisions, access requests, exception approvals, incident tickets, training evidence, configuration baselines, audit results, and management review notes where relevant.

13. Exceptions and Risk Acceptance

This section explains how the secure software development lifecycle policy is applied for exceptions and risk acceptance. The company expects every business unit to translate these requirements into practical working procedures, system settings, and evidence records. Teams must consider exception request, compensating controls, expiry, approval authority when designing controls, approving exceptions, and performing periodic reviews. Where a business process cannot meet the requirement exactly, the owner must document the risk, define compensating controls, agree an expiry date, and obtain approval before continuing. This policy is intended to be used as a detailed baseline and must be tailored to local laws, contract obligations, customer commitments, and the organization-specific operating model.

The control objective for this page is to make exception request measurable, repeatable, and auditable. Policy owners should convert the statements below into standard operating procedures, workflow controls, employee guidance, and system configuration baselines. Each requirement should be traceable to a business risk, a responsible role, and a retained evidence artifact.

Mandatory requirements

- A formal owner must be accountable for exceptions and risk acceptance decisions, approvals, escalations, and evidence retention.
- Any activity covered by this policy must follow least privilege, need-to-know access, approved tools, and documented business justification.
- Sensitive information must be classified, labeled, stored, transmitted, retained, and disposed of only through approved company processes.
- Exceptions must be time-bound, risk-assessed, approved by the correct authority, and reviewed before expiry.
- Control failures, suspected incidents, policy violations, or unusual behavior must be reported promptly through the approved security or IT support channel.
- Managers must ensure their teams understand applicable procedures and complete required training before handling regulated, confidential, or customer data.

Implementation guidance

Implementation should start by confirming system scope, business owner, data classification, user groups, and supporting procedures. The IT team should define configuration standards, monitoring requirements, escalation thresholds, and audit evidence before production rollout. Business teams should document where the policy affects daily work, customer obligations, data sharing, procurement, engineering, support operations, and exception handling.

Review questions

- Confirm the policy owner and backup owner are assigned.
- Verify scope includes employees, contractors, systems, and third parties where applicable.
- Classify related data and confirm approved storage locations.
- Document approval, exception, and escalation paths.
- Define evidence records needed for audit and compliance review.

Records to retain: approval records, risk decisions, access requests, exception approvals, incident tickets, training evidence, configuration baselines, audit results, and management review notes where relevant.

14. Compliance and Audit Evidence

This section explains how the secure software development lifecycle policy is applied for compliance and audit evidence. The company expects every business unit to translate these requirements into practical working procedures, system settings, and evidence records. Teams must consider evidence records, control testing, internal audit, customer assurance when designing controls, approving exceptions, and performing periodic reviews. Where a business process cannot meet the requirement exactly, the owner must document the risk, define compensating controls, agree an expiry date, and obtain approval before continuing. This policy is intended to be used as a detailed baseline and must be tailored to local laws, contract obligations, customer commitments, and the organization-specific operating model.

The control objective for this page is to make evidence records measurable, repeatable, and auditable. Policy owners should convert the statements below into standard operating procedures, workflow controls, employee guidance, and system configuration baselines. Each requirement should be traceable to a business risk, a responsible role, and a retained evidence artifact.

Mandatory requirements

- A formal owner must be accountable for compliance and audit evidence decisions, approvals, escalations, and evidence retention.
- Any activity covered by this policy must follow least privilege, need-to-know access, approved tools, and documented business justification.
- Sensitive information must be classified, labeled, stored, transmitted, retained, and disposed of only through approved company processes.
- Exceptions must be time-bound, risk-assessed, approved by the correct authority, and reviewed before expiry.
- Control failures, suspected incidents, policy violations, or unusual behavior must be reported promptly through the approved security or IT support channel.
- Managers must ensure their teams understand applicable procedures and complete required training before handling regulated, confidential, or customer data.

Implementation guidance

Implementation should start by confirming system scope, business owner, data classification, user groups, and supporting procedures. The IT team should define configuration standards, monitoring requirements, escalation thresholds, and audit evidence before production rollout. Business teams should document where the policy affects daily work, customer obligations, data sharing, procurement, engineering, support operations, and exception handling.

Review questions

- Confirm the policy owner and backup owner are assigned.
- Verify scope includes employees, contractors, systems, and third parties where applicable.
- Classify related data and confirm approved storage locations.
- Document approval, exception, and escalation paths.
- Define evidence records needed for audit and compliance review.

Records to retain: approval records, risk decisions, access requests, exception approvals, incident tickets, training evidence, configuration baselines, audit results, and management review notes where relevant.

15. Training and Awareness

This section explains how the secure software development lifecycle policy is applied for training and awareness. The company expects every business unit to translate these requirements into practical working procedures, system settings, and evidence records. Teams must consider onboarding, annual training, role-based training, attestation when designing controls, approving exceptions, and performing periodic reviews. Where a business process cannot meet the requirement exactly, the owner must document the risk, define compensating controls, agree an expiry date, and obtain approval before continuing. This policy is intended to be used as a detailed baseline and must be tailored to local laws, contract obligations, customer commitments, and the organization-specific operating model.

The control objective for this page is to make onboarding measurable, repeatable, and auditable. Policy owners should convert the statements below into standard operating procedures, workflow controls, employee guidance, and system configuration baselines. Each requirement should be traceable to a business risk, a responsible role, and a retained evidence artifact.

Mandatory requirements

- A formal owner must be accountable for training and awareness decisions, approvals, escalations, and evidence retention.
- Any activity covered by this policy must follow least privilege, need-to-know access, approved tools, and documented business justification.
- Sensitive information must be classified, labeled, stored, transmitted, retained, and disposed of only through approved company processes.
- Exceptions must be time-bound, risk-assessed, approved by the correct authority, and reviewed before expiry.
- Control failures, suspected incidents, policy violations, or unusual behavior must be reported promptly through the approved security or IT support channel.
- Managers must ensure their teams understand applicable procedures and complete required training before handling regulated, confidential, or customer data.

Implementation guidance

Implementation should start by confirming system scope, business owner, data classification, user groups, and supporting procedures. The IT team should define configuration standards, monitoring requirements, escalation thresholds, and audit evidence before production rollout. Business teams should document where the policy affects daily work, customer obligations, data sharing, procurement, engineering, support operations, and exception handling.

Review questions

- Confirm the policy owner and backup owner are assigned.
- Verify scope includes employees, contractors, systems, and third parties where applicable.
- Classify related data and confirm approved storage locations.
- Document approval, exception, and escalation paths.
- Define evidence records needed for audit and compliance review.

Records to retain: approval records, risk decisions, access requests, exception approvals, incident tickets, training evidence, configuration baselines, audit results, and management review notes where relevant.

16. Third Party Considerations

This section explains how the secure software development lifecycle policy is applied for third party considerations. The company expects every business unit to translate these requirements into practical working procedures, system settings, and evidence records. Teams must consider supplier access, contract obligations, shared responsibility, offboarding when designing controls, approving exceptions, and performing periodic reviews. Where a business process cannot meet the requirement exactly, the owner must document the risk, define compensating controls, agree an expiry date, and obtain approval before continuing. This policy is intended to be used as a detailed baseline and must be tailored to local laws, contract obligations, customer commitments, and the organization-specific operating model.

The control objective for this page is to make supplier access measurable, repeatable, and auditable. Policy owners should convert the statements below into standard operating procedures, workflow controls, employee guidance, and system configuration baselines. Each requirement should be traceable to a business risk, a responsible role, and a retained evidence artifact.

Mandatory requirements

- A formal owner must be accountable for third party considerations decisions, approvals, escalations, and evidence retention.
- Any activity covered by this policy must follow least privilege, need-to-know access, approved tools, and documented business justification.
- Sensitive information must be classified, labeled, stored, transmitted, retained, and disposed of only through approved company processes.
- Exceptions must be time-bound, risk-assessed, approved by the correct authority, and reviewed before expiry.
- Control failures, suspected incidents, policy violations, or unusual behavior must be reported promptly through the approved security or IT support channel.
- Managers must ensure their teams understand applicable procedures and complete required training before handling regulated, confidential, or customer data.

Implementation guidance

Implementation should start by confirming system scope, business owner, data classification, user groups, and supporting procedures. The IT team should define configuration standards, monitoring requirements, escalation thresholds, and audit evidence before production rollout. Business teams should document where the policy affects daily work, customer obligations, data sharing, procurement, engineering, support operations, and exception handling.

Review questions

- Confirm the policy owner and backup owner are assigned.
- Verify scope includes employees, contractors, systems, and third parties where applicable.
- Classify related data and confirm approved storage locations.
- Document approval, exception, and escalation paths.
- Define evidence records needed for audit and compliance review.

Records to retain: approval records, risk decisions, access requests, exception approvals, incident tickets, training evidence, configuration baselines, audit results, and management review notes where relevant.

17. Metrics and Reporting

This section explains how the secure software development lifecycle policy is applied for metrics and reporting. The company expects every business unit to translate these requirements into practical working procedures, system settings, and evidence records. Teams must consider KPIs, KRIs, dashboarding, review meetings, management reporting when designing controls, approving exceptions, and performing periodic reviews. Where a business process cannot meet the requirement exactly, the owner must document the risk, define compensating controls, agree an expiry date, and obtain approval before continuing. This policy is intended to be used as a detailed baseline and must be tailored to local laws, contract obligations, customer commitments, and the organization-specific operating model.

The control objective for this page is to make KPIs measurable, repeatable, and auditable. Policy owners should convert the statements below into standard operating procedures, workflow controls, employee guidance, and system configuration baselines. Each requirement should be traceable to a business risk, a responsible role, and a retained evidence artifact.

Mandatory requirements

- A formal owner must be accountable for metrics and reporting decisions, approvals, escalations, and evidence retention.
- Any activity covered by this policy must follow least privilege, need-to-know access, approved tools, and documented business justification.
- Sensitive information must be classified, labeled, stored, transmitted, retained, and disposed of only through approved company processes.
- Exceptions must be time-bound, risk-assessed, approved by the correct authority, and reviewed before expiry.
- Control failures, suspected incidents, policy violations, or unusual behavior must be reported promptly through the approved security or IT support channel.
- Managers must ensure their teams understand applicable procedures and complete required training before handling regulated, confidential, or customer data.

Control area	Minimum expectation	Evidence example
Ownership	A named owner maintains this policy and related standards.	Policy approval record and review log
Risk review	Policy controls are reviewed against business risk and threat changes.	Risk register entry or review minutes
Access control	Access is approved, limited, and removed when no longer needed.	Access request, approval, and review evidence
Monitoring	Relevant system activity is logged and reviewed using approved tools.	Alert queue, audit log, or SIEM report
Training	Affected users complete applicable training before using the process.	Training completion report

Records to retain: approval records, risk decisions, access requests, exception approvals, incident tickets, training evidence, configuration baselines, audit results, and management review notes where relevant.

18. Enforcement and Consequences

This section explains how the secure software development lifecycle policy is applied for enforcement and consequences. The company expects every business unit to translate these requirements into practical working procedures, system settings, and evidence records. Teams must consider violations, investigation, corrective action, discipline, remediation when designing controls, approving exceptions, and performing periodic reviews. Where a business process cannot meet the requirement exactly, the owner must document the risk, define compensating controls, agree an expiry date, and obtain approval before continuing. This policy is intended to be used as a detailed baseline and must be tailored to local laws, contract obligations, customer commitments, and the organization-specific operating model.

The control objective for this page is to make violations measurable, repeatable, and auditable. Policy owners should convert the statements below into standard operating procedures, workflow controls, employee guidance, and system configuration baselines. Each requirement should be traceable to a business risk, a responsible role, and a retained evidence artifact.

Mandatory requirements

- A formal owner must be accountable for enforcement and consequences decisions, approvals, escalations, and evidence retention.
- Any activity covered by this policy must follow least privilege, need-to-know access, approved tools, and documented business justification.
- Sensitive information must be classified, labeled, stored, transmitted, retained, and disposed of only through approved company processes.
- Exceptions must be time-bound, risk-assessed, approved by the correct authority, and reviewed before expiry.
- Control failures, suspected incidents, policy violations, or unusual behavior must be reported promptly through the approved security or IT support channel.
- Managers must ensure their teams understand applicable procedures and complete required training before handling regulated, confidential, or customer data.

Implementation guidance

Implementation should start by confirming system scope, business owner, data classification, user groups, and supporting procedures. The IT team should define configuration standards, monitoring requirements, escalation thresholds, and audit evidence before production rollout. Business teams should document where the policy affects daily work, customer obligations, data sharing, procurement, engineering, support operations, and exception handling.

Review questions

- Confirm the policy owner and backup owner are assigned.
- Verify scope includes employees, contractors, systems, and third parties where applicable.
- Classify related data and confirm approved storage locations.
- Document approval, exception, and escalation paths.
- Define evidence records needed for audit and compliance review.

Records to retain: approval records, risk decisions, access requests, exception approvals, incident tickets, training evidence, configuration baselines, audit results, and management review notes where relevant.

19. Review, Maintenance and Versioning

This section explains how the secure software development lifecycle policy is applied for review, maintenance and versioning. The company expects every business unit to translate these requirements into practical working procedures, system settings, and evidence records. Teams must consider annual review, change history, policy owner, stakeholder input when designing controls, approving exceptions, and performing periodic reviews. Where a business process cannot meet the requirement exactly, the owner must document the risk, define compensating controls, agree an expiry date, and obtain approval before continuing. This policy is intended to be used as a detailed baseline and must be tailored to local laws, contract obligations, customer commitments, and the organization-specific operating model.

The control objective for this page is to make annual review measurable, repeatable, and auditable. Policy owners should convert the statements below into standard operating procedures, workflow controls, employee guidance, and system configuration baselines. Each requirement should be traceable to a business risk, a responsible role, and a retained evidence artifact.

Mandatory requirements

- A formal owner must be accountable for review, maintenance and versioning decisions, approvals, escalations, and evidence retention.
- Any activity covered by this policy must follow least privilege, need-to-know access, approved tools, and documented business justification.
- Sensitive information must be classified, labeled, stored, transmitted, retained, and disposed of only through approved company processes.
- Exceptions must be time-bound, risk-assessed, approved by the correct authority, and reviewed before expiry.
- Control failures, suspected incidents, policy violations, or unusual behavior must be reported promptly through the approved security or IT support channel.
- Managers must ensure their teams understand applicable procedures and complete required training before handling regulated, confidential, or customer data.

Implementation guidance

Implementation should start by confirming system scope, business owner, data classification, user groups, and supporting procedures. The IT team should define configuration standards, monitoring requirements, escalation thresholds, and audit evidence before production rollout. Business teams should document where the policy affects daily work, customer obligations, data sharing, procurement, engineering, support operations, and exception handling.

Review questions

- Confirm the policy owner and backup owner are assigned.
- Verify scope includes employees, contractors, systems, and third parties where applicable.
- Classify related data and confirm approved storage locations.
- Document approval, exception, and escalation paths.
- Define evidence records needed for audit and compliance review.

Records to retain: approval records, risk decisions, access requests, exception approvals, incident tickets, training evidence, configuration baselines, audit results, and management review notes where relevant.